

Denali Health — CMS Blue Button Production Access Demo

Quick Reference Q&A

Prepared April 14, 2026

This document mirrors the exact checklist CMS sent us for the Blue Button production access demo. Each section corresponds to a heading in the CMS reviewer's checklist.

Section 1 — Be Prepared to Show

The eight items CMS said they would ask us to demonstrate during the live demo.

1. How a user would log into your application

OTP-based email authentication via AWS Cognito + AWS SES. The user enters their email, receives a 6-digit code, and verifies it. The signup page includes an active opt-in checkbox (unchecked by default) for Terms of Service and Privacy Policy — the Send Code button is disabled until the checkbox is checked.

2. How a user would authorize access to their Medicare data via Medicare.gov

MyHealth > "Connect Your Medicare" with a 3-step explainer: "Sign in with your Medicare account," "Approve read-only access to your data," "See your claims and coverage here." Pre-authorization messaging includes "Your data stays private and encrypted" and "We only read your data — we never modify it." The CMS attribution notice is visible on this page. OAuth 2.0 PKCE flow redirects to Medicare.gov for identity verification and consent.

3. How the enrollee's Medicare data is used within the application

Three uses, all consent-gated. (a) The Health hub displays conditions, coverage, providers, diabetes care, and claims from transformed summaries — never raw FHIR. (b) AI chat provides personalized coverage guidance using Medicare data, only when the user enables the "Use health data in AI conversations" toggle (OFF by default). The AI sees conditions, medications (detailed for diabetes/obesity, count-only for others), coverage status, and recent claims. (c) Appeal letter generation uses conversation context plus tool lookups (ICD-10, CPT, PubMed, LCDs/NCDs) to draft formal appeal letters.

4. How a user can terminate their application profile / account

Settings > Danger Zone > Delete Account. A confirmation dialog lists what will be deleted (conversations, appeals, Medicare data, subscriptions). A transaction-wrapped cascade deletes all user data across 18 tables. Audit logs survive with user_id set to NULL (HIPAA 6-year retention). The Cognito identity is deleted as the final step. The user is redirected to the landing page.

5. How a user can delete their Medicare data from the application

MyHealth > "Disconnect Medicare" opens a confirmation dialog: "Are you sure? This will permanently delete all cached health data, health reports, and diabetes insights. This action cannot be undone." The dialog has Cancel and "Yes, Disconnect" buttons. All fhir_cache, health_reports, ehr_connections, and diabetes data rows are deleted immediately.

6. Where a user can find your privacy policy and terms of service

Linked in the site footer on every page (Privacy Policy, Terms of Service, HIPAA). Also linked on the signup page before any data entry, and on the Connect Medicare page. Both documents are publicly accessible with no authentication required.

7. How a user accepts / opts into your privacy policy and terms of service

The signup page shows an unchecked checkbox: "I have read and agree to the Terms of Service and Privacy Policy" with clickable links. The Send Code button is disabled until the checkbox is checked. This is active opt-in, not default agreement.

8. If your application sends automated communications, show how a user can opt out

Settings > Email Alerts lists 4 alert types: appeal deadline reminders, medication refill gaps, new claim denials, and Medicare data refresh. Toggles render based on the user's subscription tier. Plus-tier users see interactive toggles for 2 alerts (appeal deadline reminders and new claim denials). Unlimited-tier users see toggles for all 4. Alerts not included in the user's current tier display a tier badge instead of a toggle. Every toggle is OFF by default - users must explicitly opt in. The only non-optional emails are the OTP sign-in code (transactional, required for authentication) and regulatory policy-change notices (required by Terms §12 / Privacy §15).

Section 2 — Be Prepared to Discuss

The eight topics CMS said they would ask us to explain verbally during the demo.

1. Does your application require the enrollee's demographic data? If so, why?

We extract only age and gender from the Patient resource — for clinical context such as age-appropriate screening recommendations and gender-specific coverage rules. We never store names, dates of birth, addresses, or Medicare Beneficiary IDs. If the enrollee unchecks "Personal Information" on the Medicare.gov consent screen, the app still functions fully.

2. How your application keeps Medicare data secure at rest and in transit

In transit: TLS 1.2+ for all connections. At rest: RDS AES-256 encryption via an AWS KMS key. OAuth tokens have additional app-layer AES-256-GCM encryption. The database is private within the VPC with no public endpoint. There is a 30-minute HIPAA session timeout with on-screen warning. Cookies are HttpOnly, Secure, and SameSite.

3. Whether your application uses FHIR STU3 or R4

R4. We use the CARIN Blue Button Implementation Guide based on FHIR R4, which is what the Blue Button 2.0 API provides.

4. If using STU3, migration plan to R4?

N/A — we built on R4 from the start.

5. Technology stack and why you chose it

Next.js 16 with React 19 and TypeScript strict mode on AWS ECS Fargate. PostgreSQL 16.9 on RDS. Claude AI via AWS Bedrock (Sonnet 4.6 for chat, Opus 4.6 for appeals). AWS SES for email. Stripe for payments (test mode until CMS approval). We chose AWS for HIPAA eligibility and BAA coverage across all services — database, hosting, AI, and email are all under one BAA signed February 25, 2026.

6. How your application will secure the BB2.0 production credentials

AWS Secrets Manager, encrypted at rest, accessed only by the ECS task role via IAM policy. Credentials never appear in source code, environment files, or logs. We have a secrets-scanner hook in our CI that blocks commits containing 13 credential patterns (AWS keys, Stripe keys, API tokens, private keys, JWTs).

7. How your application will store and secure the enrollee's authorization token

OAuth tokens are stored in the ehr_connections table with app-layer AES-256-GCM encryption on top of RDS encryption. Tokens are scoped per-user and deleted on disconnect or account deletion. The encryption key is stored in AWS Secrets Manager. Tokens are never logged. Access tokens are refreshed silently - the user never

re-authenticates for day-to-day use. When the 13-month CMS authorization window expires, the connection is marked expired and the user sees the Connect Medicare flow again. We never store or retry credentials beyond what CMS grants.

8. The lifecycle of claims data as it moves through your application

Raw FHIR bundles are fetched from the Blue Button API, processed in memory by 8 extractors (conditions, medications, screenings, coverage, providers, hospitalizations, DME, hospice), and discarded. Raw bundles are never stored. Transformed summaries are cached in PostgreSQL (RDS AES-256). The cache refreshes every 24 hours. Data is deleted on disconnect or account deletion. When the AI consent toggle is ON, the transformed summaries are sent to Claude via AWS Bedrock — conditions, medications (detailed for diabetes/obesity, count-only for others), coverage, and recent claims.

Section 3 — We Will Assess

The four criteria CMS said they would evaluate against while watching the demo.

1. Is it clear to the Medicare enrollee what their data is being used for?

Yes. The Connect Medicare page explains data usage before authorization. Three consent toggles in Settings each describe their purpose in plain English. The AI toggle specifically discloses "This data is sent to Anthropic's Claude AI to generate personalized guidance." Every AI response is labeled "AI-generated · May contain errors · Not medical advice."

2. Does the explanation occur prior to authorization or during the process?

Prior. The Connect Medicare page shows a 3-step explainer, "read-only access" language, "Your data stays private and encrypted," and the CMS attribution notice — all before the user clicks "Connect Medicare" and is redirected to Medicare.gov.

3. Are your privacy policy and terms of service easily accessible?

Yes. Linked in the footer on every page. Linked on the signup page before any data entry. Linked on the Connect Medicare page. Both are publicly accessible without authentication.

4. Is it clear to the user that their Medicare data will not be sold?

Yes. Privacy Policy §5 states "We do not sell your personal information or health data" and §14 (CCPA/CPRA Rights) reaffirms this. Both lines are referenced by line number in our internal audit.

Section 4 — Additional Q&A

Likely follow-up questions not on the checklist but within the scope of the review.

Q: What is the CMS attribution notice and where does it appear?

The exact verbatim text — "This product uses the Blue Button APIs but is not endorsed or certified by the Centers for Medicare & Medicaid Services or the U.S. Department of Health and Human Services" — appears in 9 locations: Terms §14, site footer, Connect Medicare page, CMS Pledge component, health report view, health page, appeal letter modal (2 locations), and appeal PDF.

Q: How does the appeal letter feature work?

The user describes the denial in plain English. The AI (Opus 4.6) identifies the denial type, looks up ICD-10/CPT codes, searches Medicare coverage policies (LCDs/NCDs), pulls PubMed clinical evidence, verifies the provider via the NPI Registry, and generates a formal Level 1/2/3 appeal letter. The letter uses blank lines for sensitive fields (MBI, claim number, date of service) that the user fills in by hand. Every letter carries the prominent disclaimer: "This is a DRAFT letter generated by AI. It is NOT legal advice."

Q: What audit trail exists?

An append-only audit_logs table with REVOKE UPDATE/DELETE/TRUNCATE applied at the database level. Logged events include login, logout, FHIR data access, appeal generation, appeal outcomes, and account deletion. Audit logs survive account deletion with user_id set to NULL per HIPAA 6-year retention.

Q: Is payment processing live?

Stripe is integrated in test mode — the full subscription flow works (plan selection, upgrade, cancellation) but no real charges are processed. We will switch to Stripe production mode after receiving CMS production access approval. Stripe is PCI DSS certified.

Q: What is the readability level of your privacy policy?

We ran Flesch-Kincaid analysis using textstat. Prose sections score grade 9-13 after our simplification pass. The aggregate score is higher (15.4) because bullet-list formatting inflates the tool's calculation. The actual prose content is accessible to a Medicare audience.

Q: Do you use "Blue Button" in any user-facing text?

Only in the CMS-mandated attribution notice. All other references use "Medicare" - "Connect Medicare," "Medicare data," "Medicare account." We removed "Blue Button" from email footers, PDF footers, and AI system prompts during our compliance audit.

Q: What happens if your company is sold?

Privacy Policy §5 requires us to notify CMS as soon as possible. Our access to Medicare data is tied to our specific company - if ownership changes, CMS must review and re-approve the new owner. Users are notified of any ownership change that could affect their data.

Q: How do you handle a data breach?

We follow the FTC Health Breach Notification Rule (16 CFR Part 318) and the HITECH Act. Affected users are notified within 60 days via email explaining what happened, what data was involved, and steps they can take - including checking Medicare Summary Notices for unfamiliar claims, calling 1-800-MEDICARE if they suspect misuse, and reviewing their credit report. CMS is notified at the earliest practicable time.

Q: What BAAs do you have and with whom?

AWS BAA signed February 25, 2026, covering RDS (database), ECS/Fargate (hosting), Bedrock (AI processing), and SES (email). Stripe is PCI DSS certified for payment processing. No other vendors handle Medicare data.

Q: What data does the AI actually see?

When the health data consent toggle is ON, Claude receives: patient age and gender, active coverage types, recent claims (top 5 with procedure/diagnosis codes and amounts), diabetes and obesity diagnoses with ICD-10 codes, diabetes and obesity medications with details, a count-only summary of other medications (no names), screening dates and overdue flags, and provider specialties. It never sees names, DOB, addresses, MBI, or raw FHIR bundles.

Q: How do you demonstrate the opt-out mechanism during the demo?

We demonstrate with a Plus-tier or Unlimited-tier account so the toggle switches render. Each toggle reads the user's alert_preferences row from the database before every email send. If the toggle is OFF - or the row does not exist, since we default to OFF per our opt-in policy - the alert engine skips that user for that alert type and no email is sent.